

OAuth2 Demystified

In the era of rapid application development and deployment as well as concerns around security and privacy, the OAuth2 authorisation is a huge boon.



delegation framework. Apps practice authorisation in other ways also. One standard way is the session token based system. The sequence diagram in Figure 1 explains this.

However, nowadays, applications are far from monolithic. They often deploy domain sharding (sub-domaining) for the resources in order to extract more parallelism out of the networking layer — layer-4 in the networking stack. Every domain needs to consult the same store of access tokens against credentials, every time a user accesses the resource. Hence, the token store is a single point of failure for the whole application ecosystem.

What is OAuth2?

OAuth2 is an authorisation standard or framework, and not really a protocol as such. It has nothing to do with authentication, but is an authorisation

Tenets of OAuth2

Table 1 lists different participants or tenets in the OAuth2 ecosystem.

When you try to access a mobile app or website (Web app), you are often asked to use your Google or Facebook account to log into it. You type in the credentials (your ID and password) and are presented with a screen that allows access to some of the information (e.g., access to your contact, access to SMS, camera, etc). You trust it and proceed. It sends a SMS with an OTP. You key in the OTP and voila, you have access to the app or website.

This is something we have done a number of times.

This article talks about the fundamental principle around this mechanism – the all-pervasive and ubiquitous Open Authorization, aka OAuth. The current version is 2 or OAuth2.

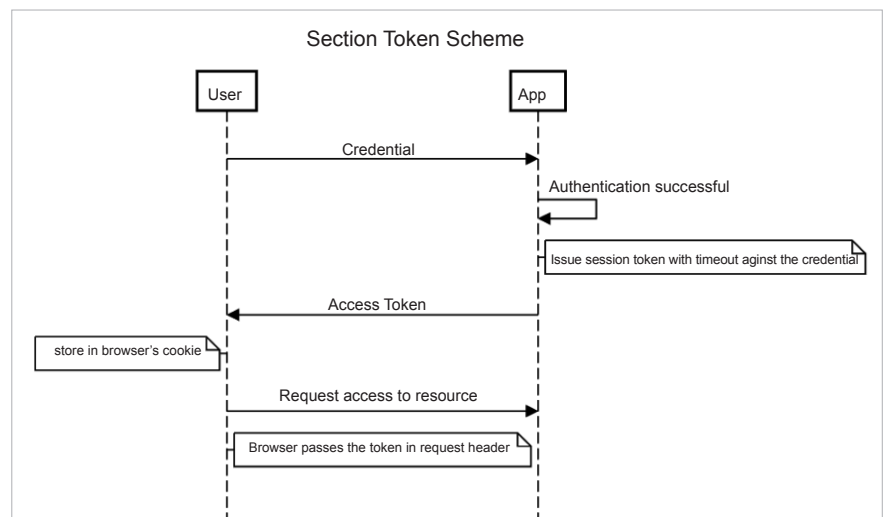


Figure 1: Access token mechanism (Please note we have used <https://sequencediagram.org> for the interaction diagrams in this article.)